

5-IDOR - Santa’s Little IDOR

Introduction



Los elfos de Wareville están en alerta máxima desde la desaparición de McSkidy. Recientemente, el equipo de soporte ha recibido numerosas llamadas de padres que no pueden activar cupones en el sitio web TryPresentMe. También mencionaron que están recibiendo numerosos correos electrónicos de phishing dirigidos con información no pública. El equipo de soporte se mantiene alerta y ha solicitado la ayuda del personal de TBFC. Al investigar este peculiar caso, descubrieron una cuenta con un nombre sospechoso, Sir Carrotbane, que tiene muchos cupones asignados. Por ahora, han eliminado la cuenta y recuperado los cupones. Pero algo está sucediendo. ¿Puedes ayudar al personal de TBFC a investigar el sitio web TryPresentMe y corregir las vulnerabilidades?

Objetivos de aprendizaje

- Comprender el concepto de autenticación y autorización
- Aprender a detectar posibles oportunidades para Referencias Directas a Objetos Inseguras (IDOR)
- Explotar IDOR para realizar una escalada horizontal de privilegios
- Aprender a convertir IDOR en SDOR (Referencia Directa a Objetos Segura)

IDOR on the Shelf

Es peligrosamente obvio, de verdad.

¿Alguna vez has visto un enlace como este: <https://awesome.website.thm/TrackPackage?packageID=1001?>

Al ver un enlace como este, ¿te has preguntado qué pasaría si simplemente cambiaras el ID del paquete a 11 o 12? En su forma más simple, este podría ser un caso potencial de IDOR.

IDOR significa Referencia Directa a Objetos Insegura y es un tipo de vulnerabilidad de control de acceso. Las aplicaciones web suelen usar referencias para determinar qué datos devolver al realizar una solicitud. Sin embargo, si el servidor web no realiza comprobaciones para garantizar que se le permita ver esos datos antes de enviarlos, puede provocar una grave divulgación de información confidencial. Una buena pregunta es:

¿Por qué sucede esto tan a menudo?

Necesitamos comprender mejor las referencias y el desarrollo web para responder a esta pregunta. Veamos cómo se vería una tabla que almacenara los números de paquete de nuestro ejemplo de enlace:

packageID	person	address	status
1001	Alice Smith	123 Main St, Springfield	Delivered
1002	Bob Johnson	42 Elm Ave, Shelbyville	In Transit
1003	Carol White	9 Oak Rd, Capital City	Out for Delivery
1004	Daniel Brown	77 Pine St, Ogdenville	Pending
1005	Eve Martinez	5 Maple Ln, North Haverbrook	Returned

Si el usuario desea conocer el estado de su paquete y realiza una solicitud web, el método más sencillo es permitirle proporcionar su ID de paquete. Recuperamos los datos de la base de datos mediante la consulta SQL más simple:

```
SELECT person, address, status FROM Packages WHERE packageID = value;
```

Sin embargo, dado que packageID es un número secuencial, resulta bastante obvio adivinar los packageID de otros clientes. Además, dado que la aplicación web no verifica que la persona que realiza la solicitud sea la misma que la propietaria del paquete, surge una vulnerabilidad IDOR, que permite a los atacantes recuperar los detalles de los paquetes que pertenecen a otros usuarios. Peor aún es cuando una función como esta no requiere la autenticación del usuario, ya que no habría forma de saber quién realiza la solicitud. Para profundizar un poco más, necesitamos comprender la autenticación, la autorización y la escalada de privilegios.

Una nota de uno de los coautores de esta tarea:

No me convence el nombre de la vulnerabilidad IDOR. Prefiero el nombre "Omisión de autorización". Si quieres entender mi razonamiento, amplía la información aquí, ¡pero no te aburras con los detalles!

Obviamente no está relacionado

El término completo, Referencia Directa a Objetos Insegura, suena sofisticado, pero no describe realmente qué está fallando. La parte "Referencia Directa a Objetos" simplemente significa que un sistema usa un ID (como /user/1) para apuntar a algo. Ese no es el problema. El verdadero problema es que el sistema no comprueba si la persona que realiza la solicitud tiene permiso para acceder a él.

Mucha gente intenta "arreglar" los IDOR ocultándolos o codificándolos. Por ejemplo, cambiando /user/1 por /user/ea21f09b2. Eso podría hacer que parezca más difícil de adivinar, pero si el servidor sigue sin comprobar los permisos, es igual de inseguro. La vulnerabilidad no radica en cómo se referencia el objeto, sino en la omisión de las comprobaciones de autorización.

Por eso prefiero llamarlo "Omisión de Autorización". Explica exactamente lo que sucede: alguien está eludiendo las reglas que deciden quién puede ver o modificar algo. Ya sea que el ID sea un número, un hash o una cadena aleatoria, el riesgo es el mismo si el servidor no verifica el acceso. Puedes leer más [aquí](#) si quieres.

La identidad define nuestro alcance

Para comprender la causa raíz de IDOR, es importante comprender los principios básicos de autenticación y autorización:

- **Autenticación:** El proceso mediante el cual usted verifica su identidad. Por ejemplo, al proporcionar su nombre de usuario y contraseña.
- **Autorización:** El proceso mediante el cual la aplicación web verifica sus permisos. Por ejemplo, ¿puede visitar la página de administración de una aplicación web o realizar un pago con una cuenta específica?

Puede pensar que la autenticación solo se realiza una vez al proporcionar su nombre de usuario y contraseña, ¡pero no es así! Después de proporcionar sus credenciales, recibe una cookie o token, denominado información de sesión. Cada solicitud posterior que realiza a la aplicación incluye esta información de sesión, que es verificada por la aplicación. Este proceso de verificación inicial sigue siendo autenticación y se realiza para cada solicitud. Por eso, los sitios web a menudo le redirigen a la página de inicio de sesión. Esto significa que su información de sesión ha expirado y, por lo tanto, debe volver a autenticarse con sus credenciales para recibir nueva información de sesión.

La autorización no puede realizarse antes de la autenticación. Si la aplicación no sabe quién eres, no podrá verificar los permisos de tu usuario. Es muy importante recordar esto. Si tu IDOR no requiere autenticación (iniciar sesión o proporcionar información de sesión), como en nuestro ejemplo de seguimiento de paquetes, primero tendremos que solucionar el problema de autenticación antes de poder solucionar el de autorización, que consiste en garantizar que los usuarios solo puedan obtener información sobre los paquetes que poseen.

El último aspecto teórico que abordaremos son los tipos de escalada de privilegios:

- **Escalada de privilegios vertical:** Se refiere a la escalada de privilegios donde obtienes acceso a más funciones. Por ejemplo, puedes ser un usuario normal de la aplicación, pero puedes realizar acciones que deberían estar restringidas para un administrador.
- **Escalada de privilegios horizontal:** Se refiere a la escalada de privilegios donde usas una función para la que estás autorizado, pero obtienes acceso a datos a los que no tienes acceso. Por ejemplo, solo deberías poder ver tus cuentas, no las de otros.

IDOR suele ser una forma de escalada de privilegios horizontal. Puedes usar la función de seguimiento de paquetes, pero deberías estar restringido a realizar esa acción de seguimiento solo para los paquetes que posees. Ahora que entendemos la teoría, ¡veamos cómo aprovechar IDOR en la práctica!

Iterar dígitos, observar respuestas

Comencemos con el ejemplo más simple de IDOR. En la aplicación web, autentiquemos la aplicación usando los siguientes datos.

Credentials

Username

 niels

Password

 TryHackMe#2025

IP address/Website

 http://MACHINE_IP

Una vez autenticado, deberías ver un panel como este:

 TrypresentMe

Parent Dashboard

 niels

Logout

Account Information

Email

niels@webmail.thm

ID Number

NIELS-001

Address

42 chill Street

My Children

Manage gift wishes for your children

Bilbo

Born: 2008-05-01

Voucher

Add Gift

0/1 gifts

johny

Born: 1920-10-01

Voucher

Add Gift

0/1 gifts

johny

Born: 1996-10-25

Voucher

Add Gift

0/1 gifts

Terst

Born: 2025-10-06

Voucher

Add Gift

0/1 gifts

Test2

Born: 2025-06-03

Voucher

Add Gift

0/1 gifts

My Vouchers

Track your extra gift vouchers

Total Extra Gifts

6

Claim Voucher

Available Vouchers (6)

37f0010f-a489-11f0-ac99-026ccdf7d769

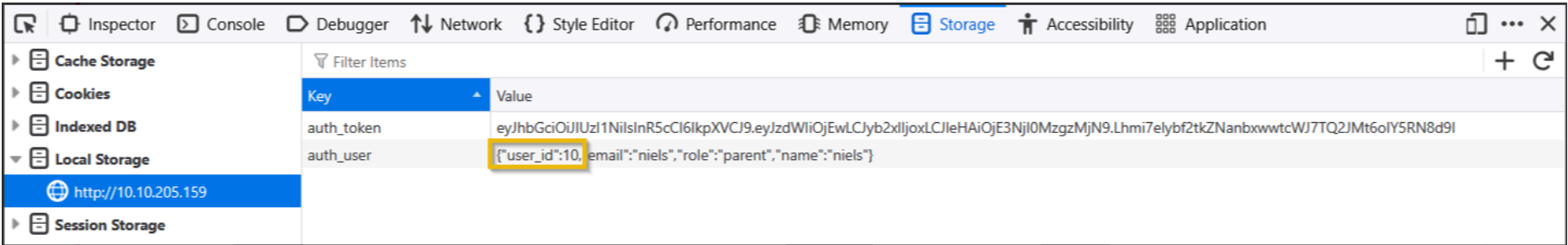
+1 Gifts

Used Vouchers (5)

76291800-a457-11f0-be28-026ccdf7d769

+1 Gifts

Comencemos usando las **Herramientas de Desarrollo** de nuestro navegador para comprender mejor qué sucede en segundo plano. Haga clic derecho en la página y seleccione Inspeccionar. Luego, haga clic en la pestaña **Network**, como se muestra a continuación:

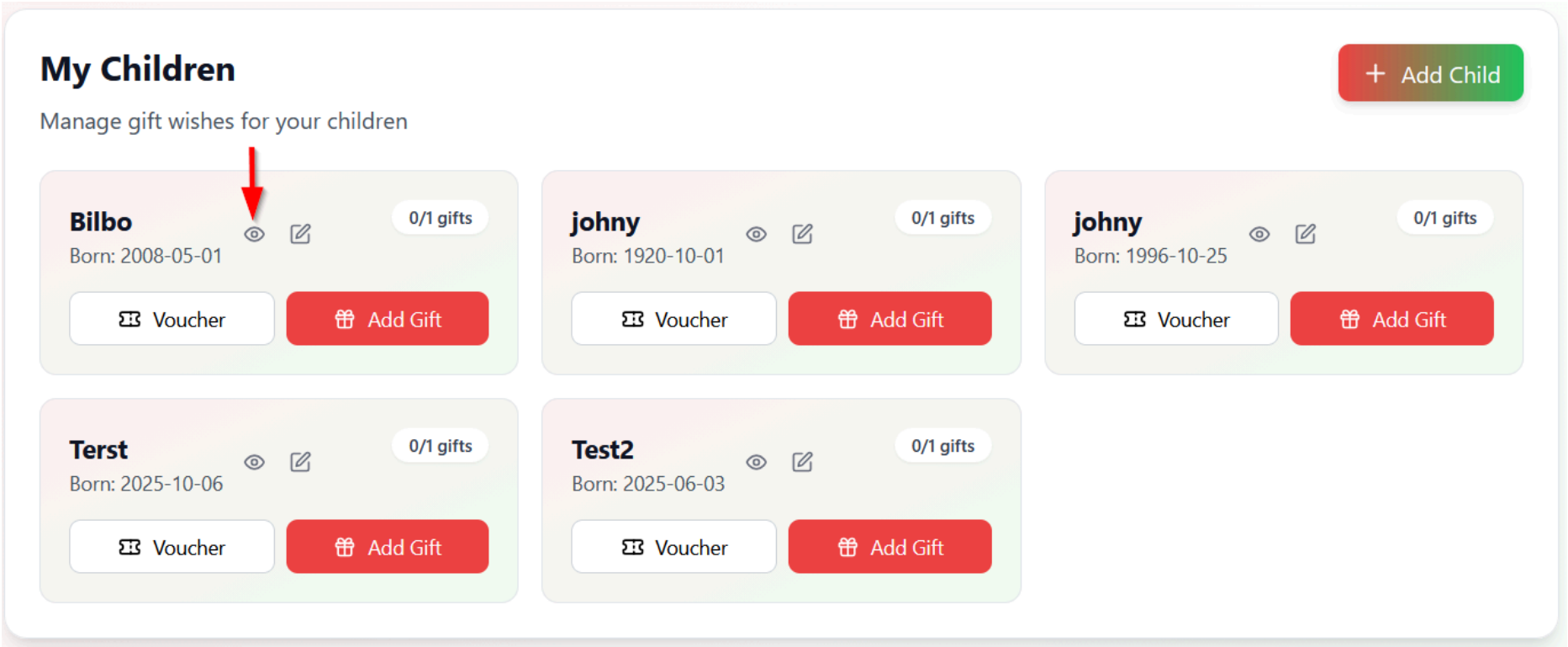


Cambiamos el `user_id` a 11 y veamos qué sucede. Haz doble clic en el campo Value de la entrada de datos `auth_user` , actualiza el `user_id` a 11 y guárdalo pulsando Intro. Ahora, actualiza la página. ¡De repente, parece que eres un usuario completamente diferente!

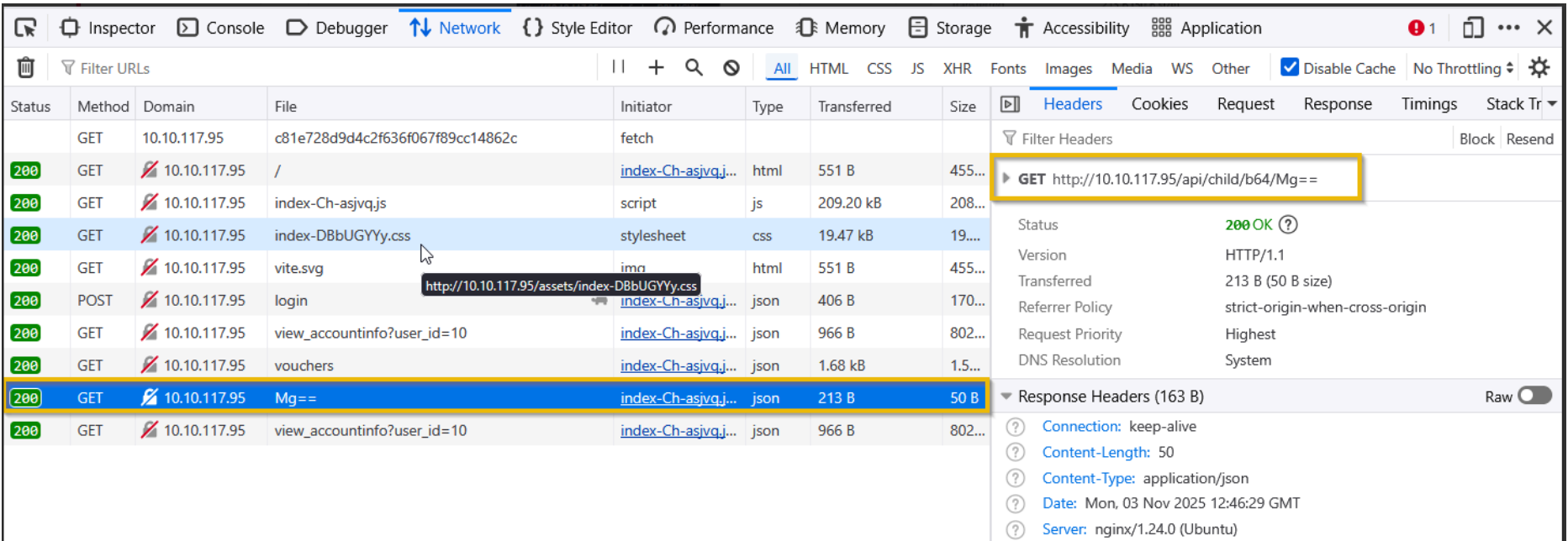
Esta es la forma más simple de IDOR. Simplemente cambiando el `user_id` a otro valor, podremos ver los datos de otros usuarios. Algunos IDOR pueden estar un poco más ocultos. ¡Que no veas un número directo no significa que no exista! Profundicemos. Para continuar con los siguientes desafíos de la tarea, cambia el id de nuevo a 10 siguiendo los mismos pasos que seguiste anteriormente. También puedes cerrar sesión en la aplicación y volver a iniciarla con el nombre de usuario y la contraseña.

In Disguise: Referencias obvias

A veces, el IDOR puede no ser tan simple como un simple número. En ciertos casos, es posible que se haya utilizado codificación. En el perfil cargado, haz clic en el icono del ojo junto al primer hijo, como se muestra en la imagen de abajo.



Ahora vuelve a la pestaña Red y observa las solicitudes que se están realizando; deberías ver una solicitud como esta:



En pocas palabras, `Mg==` es simplemente la versión codificada en base64 del número 2. Se podría realizar IDOR usando esta solicitud, pero primero habría que codificar el número en base64.

En los resúmenes, los objetos permanecen

La codificación no es lo único que se puede usar para ocultar posibles vulnerabilidades de IDOR. A veces, los valores pueden parecerse a un hash, como MD5 o SHA1. Si quieres ver cómo se vería, observa la solicitud que se realiza al hacer clic en el icono de edición junto a un elemento secundario.

InspectorConsoleDebuggerNetworkStyle EditorPerformanceMemoryStorageAccessibilityApplication

Filter URLs

AllHTMLCSSJSXHRFontsImagesMediaWSOther

Disable CacheNo Throttling

Stat...	Met...	Domain	File	Initiator	Type	Transferred	Si...	Headers	Cookies	Request	Response	Timings	Stack Trace
200	GET	10.10.11...	/	document	html	551 B	4...						
200	GET	10.10.11...	index-Ch-asjvq.js	script	js	209.20 kB	2...						
200	GET	10.10.11...	index-DBbUGYYy.css	stylesheet	css	19.47 kB	1...						
200	GET	10.10.11...	view_accountinfo?user_id=10	index-Ch-as...	json	966 B	8...						
200	GET	10.10.11...	vouchers	index-Ch-as...	json	1.68 kB	1....						
200	GET	10.10.11...	vite.svg	img	html	551 B	4...						
200	GET	10.10.11...	md5-BkWTu6CHjs	index-Ch-as...	js	11.50 kB	1...						
200	GET	10.10.11...	c81e728d9d4c2f636f067f89cc14862c	index-Ch-as...	json	217 B	5...						

Filter Headers

GET http://10.10.117.95/api/child/md5/c81e728d9d4c2f636f067f89cc14862c

Status200 OK

VersionHTTP/1.1

Transferred217 B (54 B size)

Referrer Policystrict-origin-when-cross-origin

DNS ResolutionSystem

Response Headers (163 B)

Connection: keep-alive

Content-Length: 54

Content-Type: application/json

Date: Mon, 03 Nov 2025 12:52:36 GMT

Server: nginx/1.24.0 (Ubuntu)

Aunque la cadena pueda parecer aleatoria, tras una investigación más profunda, se puede observar que se trata de un tipo de hash. Si comprendemos qué valor se utilizó para generar el hash, podemos realizar un ataque IDOR simplemente replicando la función hash. Usar algo como un [hash identifier](#) puede ayudar a comprender rápidamente qué algoritmo de hash se está utilizando y, a menudo, puede indicar qué datos se han codificado.

Es determinista, obviamente reproducible.

A veces es necesario investigar a fondo para encontrar el IDOR. A veces, el IDOR no es tan claro. En otras ocasiones, el IDOR se deriva del algoritmo real utilizado. En este último caso, analicemos nuestros comprobantes. Aunque los valores puedan parecer aleatorios, debemos investigar qué algoritmo se utilizó para generarlos. Su formato se parece a un UUID, así que usemos un sitio web como [UUID Decoder](#) para intentar comprender qué formato de UUID se utilizó. Copie uno de los comprobantes en el sitio web para decodificarlo y debería ver algo como esto:

 **UUID Decoder**

Enter UUID to Decode:

37f0010f-a489-11f0-ac99-026ccdf7d769

UUIDs are in the format 00000000-0000-0000-0000-000000000000. Autofill with random UUID

Decode UUID

Results:

Copy API Call

Standard String Format	37f0010f-a489-11f0-ac99-026ccdf7d769
Single Integer Value	74353712535972022174065751739197806441
Version	1 (time and node based)
Variant	DCE 1.1, ISO/IEC 11578:1996
Contents - Time	2025-10-08 20:56:10.443598.3 UTC
Contents - Clock	11417 (usually random)
Contents - Node	02:6c:cd:f7:d7:69 (local unicast)

Aunque estos parecen completamente aleatorios, podemos ver que se usó la versión 1 del UUID. El problema con el UUID 1 es que si conocemos la fecha exacta en que se generó el código, podemos recuperarlo. Por ejemplo, supongamos que supiéramos que los elfos siempre generaban cupones entre las 20:00 y las 21:00. En ese caso, podemos crear UUID para todo ese período (3600 UUID, ya que tenemos 60 minutos y 60 segundos en un minuto), que podríamos usar en un ataque de fuerza bruta para intentar recuperar un cupón válido y obtener más regalos.

Ahora que hemos visto los distintos IDOR que se pueden encontrar, ¡veamos cómo solucionarlos y evitarlos!

Mejorar el diseño, eliminar el riesgo

Ahora que sabemos qué es el IDOR, veamos cómo solucionarlo. La mejor manera de detener el IDOR es asegurarse de que el servidor verifique quién solicita los datos cada vez. No basta con ocultar o cambiar el número de ID; El sistema debe confirmar que el usuario conectado está autorizado a ver o modificar dicha información.

No confíe en trucos como Base64 o el hash de los ID; estos aún pueden adivinarse o decodificarse. En su lugar, mantenga todas las comprobaciones de permisos reales en el servidor. Cada vez que llegue una solicitud, verifique: "¿Este usuario posee o tiene permiso para ver este elemento?".

Use IDs aleatorios o difíciles de adivinar para los enlaces públicos, pero recuerde que los IDs aleatorios por sí solos no garantizan la seguridad de su aplicación. Pruebe siempre su aplicación intentando abrir los datos de otro usuario y asegurándose de que estén bloqueados. Finalmente, registre y monitoree los intentos de acceso fallidos; pueden ser señales tempranas de que alguien intenta explotar un IDOR.

Answer the questions below

What does IDOR stand for?

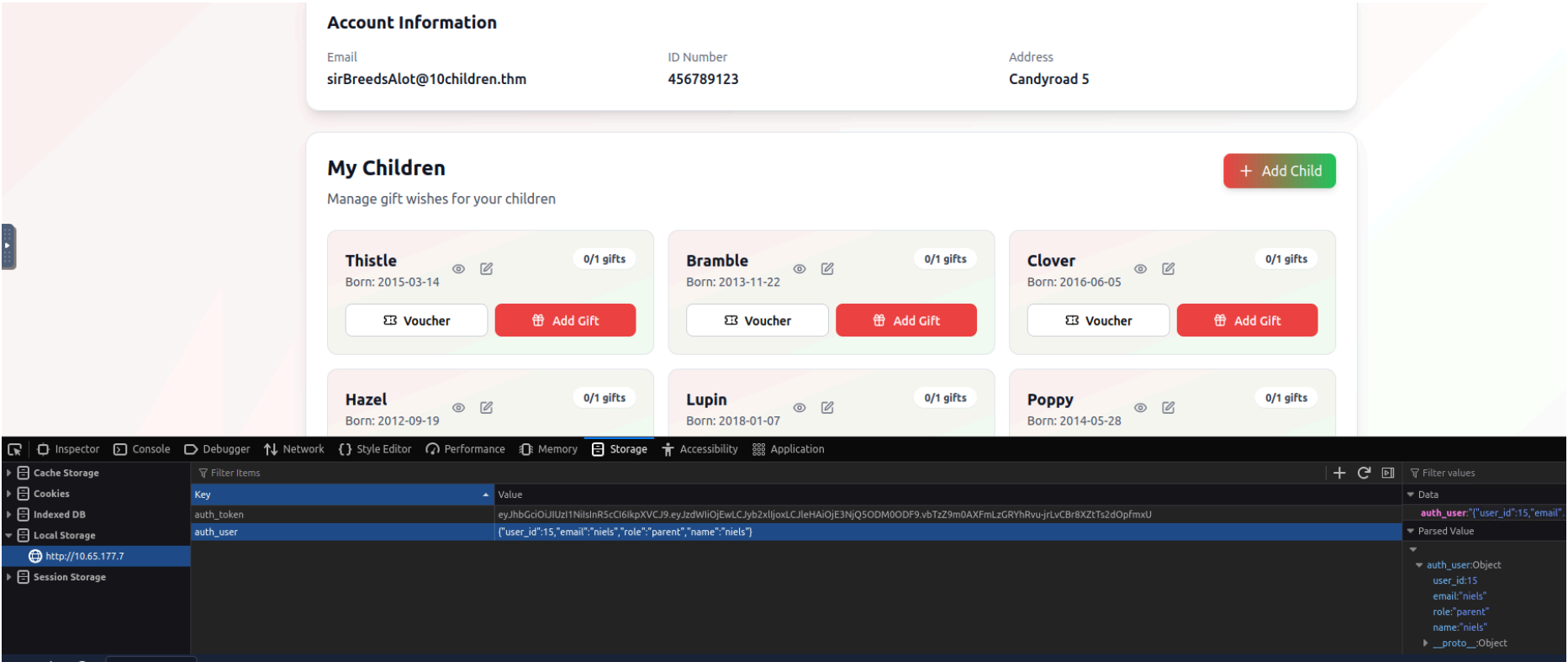
Respuesta: Insecure Direct Object Reference

What type of privilege escalation are most IDOR cases?

Respuesta: Horizontal

Exploiting the IDOR found in the `view_accounts` parameter, what is the `user_id` of the parent that has 10 children?

Respuesta: 15



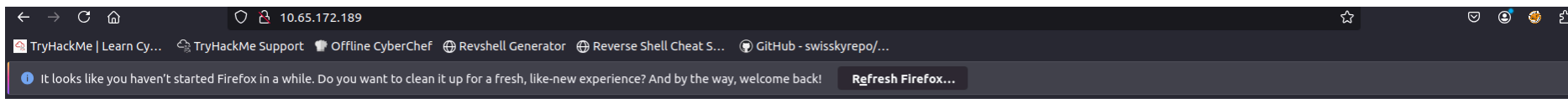
Bonus Task: If you want to dive even deeper, use either the base64 or md5 child endpoint and try to find the `id_number` of the child born on 2019-04-17? To make the iteration faster, consider using something like Burp's Intruder. If you want to check your answer, click the hint on the question.

Check

Bonus Task: Want to go even further? Using the `/parents/vouchers/claim` endpoint, find the voucher that is valid on 20 November 2025. Insider information tells you that the voucher was generated exactly on the minute somewhere between 20:00 - 24:00 UTC that day. What is the voucher code? If you want to check your answer, click the hint on the question.

Check

If you enjoyed today's room, check out our complete [IDOR](#) room!



 TrypresentMe
Parent Dashboard

niels

Logout

Account Information

Email

niels@webmail.thm

ID Number

NIELS-001

Address

42 chill Street

My Children

Manage gift wishes for your children

+ Add Child

Bilbo

Born: 2008-05-01

0/1 gifts

johny

Born: 1920-10-01

0/1 gifts

johny

Born: 1996-10-25

0/1 gifts

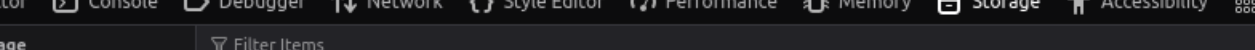
The screenshot displays the Chrome DevTools Network tab. The main pane shows a list of network requests. The selected request is 'view_accountinfo?user_id=10' with a status of 200 OK. The right sidebar shows the response details, including status, version, and headers.

Status	Method	Domain	File	Initiator	Type	Transferred	Size
304	GET	10.65.172.189	/	document	html	cached	455 B
200	GET	10.65.172.189	index-ouw-EEDW.js	script	js	cached	209.49 kB
200	GET	10.65.172.189	vite.svg	FaviconLoader.sys.mjs:175 (img)	html	cached	455 B
200	GET	10.65.172.189	view_accountinfo?user_id=10	index-ouw-EEDW.js:135 (fetch)	json	966 B	802 B
200	GET	10.65.172.189	vouchers	index-ouw-EEDW.js:135 (fetch)	json	1.68 kB	1.51 kB

Summary: 5 requests, 212.72 kB / 2.64 kB transferred, Finish: 993 ms, DOMContentLoaded: 75 ms, load: 455 ms

Selected Request: GET /10.65.172.189/api/parents/view_accountinfo?user_id=10

Status: 200 OK
Version: HTTP/1.1
Transferred: 966 B (802 B size)
Referrer Policy: strict-origin-when-cross-origin
DNS Resolution: System



The screenshot shows the Chrome DevTools interface with the Storage panel open. The left sidebar lists storage categories: Cache Storage, Cookies, Indexed DB, Local Storage, and Session Storage. The 'Cookies' category is expanded, showing a list of cookies for the URL 'http://10.65.172.189'. The 'auth_user' cookie is selected, and its value is displayed as a JSON object: {"user_id":11,"email":"niels","role":"parent","name":"niels"}. The top toolbar shows various DevTools sections: Inspector, Console, Debugger, Network, Style Editor, Performance, Memory, Storage, Accessibility, and Application.

Key	Value
auth_token	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJleWwLCyY2b2xlijozLCJleHAiOiJlE3NjQ5NTg3Mzd9.XC-V2
auth_user	{"user_id":11,"email":"niels","role":"parent","name":"niels"}

**TrypresentMe**
Parent Dashboard

niels

Logout

Account Information

Email	ID Number	Address
test@test.com	TEST-688	1 Test Lane

My Children

Manage gift wishes for your children

+ Add Child



No children added yet

+ Add Your First Child

TrypresentMe

Parent Dashboard

niels

Logout

Account Information

Email
niels@webmail.thm

My Children

Manage gift wishes for your children

Bilbo

Born: 2008-05-01

Bilbo

Born: 1920-10-01

Bilbo

Born: 1996-10-25

0/1 gifts

+ Add Child

Child Details

Bilbo

Child ID: 2

Parent Information

Close

Inspector

Console

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Filter URLs

Status	Method	Domain	File	Initiator	Type	Transferred	Size	Headers	Cookies	Request	Response
200	GET	10.65.177.7	index-ouw-EEDW.js	script	js	cached	209.49 kB	Filter Headers			
200	GET	10.65.177.7	vite.svg	FaviconLoader.sys.mjs:175 (img)	html	cached	455 B				
200	GET	10.65.177.7	view_accountinfo?user_id=10	index-ouw-EEDW.js:135 (fetch)	json	966 B	802 B			GET http://10.65.177.7/api/child/b64/Mg==	
200	GET	10.65.177.7	vouchers	index-ouw-EEDW.js:135 (fetch)	json	1.68 kB	1.51 kB				Status: 200 OK Version: HTTP/1.1 Transferred: 238 B (75 B size) Referrer Policy: strict-origin-when-cross-origin Request Priority: Highest
200	GET	10.65.177.7	Mg==	index-ouw-EEDW.js:135 (fetch)	json	238 B	75 B				
200	GET	10.65.177.7	view_accountinfo?user_id=10	index-ouw-EEDW.js:135 (fetch)	json	966 B	802 B				

7 requests | 213.59 kB / 3.85 kB transferred | Finish: 3.24 s | DOMContentLoaded: 92 ms | load: 422 ms

TrypresentMe

Parent Dashboard

niels

Logout

Account Information

Email
niels@webmail.thm

My Children

Manage gift wishes for your children

Bilbo

Born: 2008-05-01

Bilbo

Born: 1920-10-01

Bilbo

Born: 1996-10-25

0/1 gifts

+ Add Child

Edit Child

ID Number

8902035555

First Name

Bilbo

Last Name

Baggins

Birthdate

01/05/2008

Cancel

Save Changes

Inspector

Console

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Filter URLs

Status	Method	Domain	File	Initiator	Type	Transferred	Size	Headers	Cookies	Request	Response	Timings	Stack Trace
200	GET	10.65.177.7	view_accountinfo?user_id=10	index-ouw-EEDW.js:135 (fetch)	json	966 B	802 B	Filter Headers					
200	GET	10.65.177.7	vouchers	index-ouw-EEDW.js:135 (fetch)	json	1.68 kB	1.51 kB						
200	GET	10.65.177.7	Mg==	index-ouw-EEDW.js:135 (fetch)	json	238 B	75 B			GET	Scheme: http Host: 10.65.177.7 Filename: /api/child/md5/c81e728d9d4c2f636f067f89cc14862c		
200	GET	10.65.177.7	view_accountinfo?user_id=10	index-ouw-EEDW.js:135 (fetch)	json	966 B	802 B						
200	GET	10.65.177.7	md5-BkWTu6CH.js	index-ouw-EEDW.js:135 (script)	js	11.50 kB	11.24 kB						
200	GET	10.65.177.7	c81e728d9d4c2f636f067f89cc14862c	index-ouw-EEDW.js:135 (fetch)	json	242 B	79 B			Address: 10.65.177.7:80			